

Manual 20 — CIS Controls v8.1 Controlled Implementation

Controlled English master — development

****Series order:**** 20

****Boundary:**** Implementation guidance derived from current CIS Controls v8.1 concepts without reproducing protected CIS text. Keep CIS Controls, Safeguards, Implementation Groups, CIS Benchmarks, framework mappings, and organization-specific procedures distinct. Do not imply CIS certification or endorsement.

1. Purpose, scope, and source boundaries

Define organizational scope, security objectives, authoritative CIS source references, licensing/copyright constraints, and intended use. Evidence: scope statement, source register, governance approval.

2. Governance and applicability

Establish executive ownership, security governance, policy hierarchy, accountability, and applicability criteria. Evidence: charter, RACI, policy register, decision records.

3. Implementation Group selection

Select and justify the applicable Implementation Group posture using organizational risk, resources, threat exposure, data, mission, and operating complexity. Evidence: IG decision memo and reassessment triggers.

4. Enterprise asset inventory

Maintain authoritative inventories of enterprise assets, ownership, network identity, criticality, lifecycle state, and approved status. Reconcile discovery outputs and investigate unmanaged assets.

5. Software inventory and lifecycle

Maintain authorized software inventories, versions, ownership, support state, business purpose, and removal processes. Evidence: software register, discovery reconciliation, unsupported-software remediation.

6. Data protection and classification

Inventory and classify data, define handling requirements, minimize exposure, protect storage/transmission, and govern retention/disposal. Evidence: data inventory, classifications, DLP/encryption records, disposal evidence.

7. Secure configuration governance

Define approved secure configurations for enterprise assets and software, configuration ownership, deployment, drift monitoring, exceptions, and remediation. Distinguish CIS Benchmarks from CIS Controls requirements/concepts.

8. Account management

Govern creation, modification, disabling, deletion, ownership, service accounts, dormant accounts, and account inventories. Evidence: IAM records, reviews, deprovisioning samples.

9. Access-control management

Apply least privilege, role-based/attribute-based access, MFA where appropriate, periodic access review, remote-access controls, and segregation of duties. Evidence: access matrix, approvals, review outputs.

10. Vulnerability management

Define vulnerability discovery, prioritization, remediation, exceptions, validation, and metrics. Evidence: scanner coverage, findings, tickets, retests, risk acceptances.

11. Audit-log management

Define required log sources, collection, time synchronization, retention, access protection, review, and alerting. Evidence: logging standard, SIEM coverage, retention settings, review records.

12. Email and web-browser protections

Apply secure configuration, filtering, malicious-content controls, extension governance, domain protections, and user safeguards. Evidence: configurations, gateway records, allowed-extension lists, test results.

13. Malware defenses

Deploy and monitor anti-malware/endpoint protections, behavioral controls, update health, removable-media rules, and response processes. Evidence: coverage dashboards, alerts, isolation/remediation records.

14. Data recovery controls

Maintain protected backups, recovery points, offline/immutable protections where appropriate, restoration testing, access controls, and recovery objectives. Evidence: backup reports and restore-test results.

15. Network infrastructure management

Inventory and securely manage network devices, configurations, administrative interfaces, lifecycle, segmentation, and change control. Evidence: network inventory, configs, change records, review results.

16. Network monitoring and defense

Deploy monitoring, detection, filtering, segmentation, traffic analysis, and response capabilities proportionate to risk. Evidence: sensor coverage, alerts, firewall/network rules, investigation records.

17. Security awareness and skills training

Provide baseline and role-specific education covering current threats, reporting, data handling, authentication, engineering, administration, and incident roles. Evidence: curricula, completion, exercises, effectiveness metrics.

18. Service-provider management

Inventory service providers, assess risk, define contractual/security expectations, monitor performance, track incidents, and govern termination. Evidence: vendor register, assessments, agreements, monitoring records.

19. Application-software security

Integrate secure requirements, threat modeling, code review, dependency management, secrets handling, testing, release gates, and vulnerability remediation into the SDLC. Evidence: pipeline outputs, findings, approvals.

20. Incident response management

Maintain incident roles, communications, detection, triage, containment, eradication, recovery, evidence preservation, exercises, and lessons learned. Evidence: IR plan, incidents, tabletop records, improvements.

21. Penetration-testing governance

Define scope, competence/independence, rules of engagement, testing frequency, findings, remediation, and retesting. Evidence: test plans, reports, remediation records. Penetration testing does not replace broader control verification.

22. Cloud and shared-responsibility adaptation

Map safeguards across IaaS/PaaS/SaaS provider and customer responsibilities. Evidence: responsibility matrices, cloud configuration evidence, provider assurance, unresolved-gap tracking.

23. Endpoint, mobile, IoT, and remote-work adaptation

Define inventory, configuration, authentication, encryption, update, network, monitoring, and loss/compromise controls for distributed assets. Evidence: MDM/EDR coverage, device records, exception handling.

24. Safeguard-to-evidence architecture

For each implemented safeguard concept, record owner, procedure, trigger/frequency, evidence object, evidence location, test method, findings, remediation, and reassessment trigger. Evidence must support reconstruction of operation.

25. Control ownership, RACI, and cadence

Assign accountable and responsible roles, escalation paths, review cadence, deputies, and cross-functional interfaces. Test that ownership is operational, not merely documented.

26. Exceptions and compensating safeguards

Use controlled exceptions with rationale, risk, compensating safeguards, approver, expiration, remediation target, and periodic review. Evidence: exception register and closure records.

27. Measurement, metrics, and maturity

Define coverage, timeliness, effectiveness, exception, recurrence, and risk indicators. Use metrics to drive decisions without replacing qualitative risk judgment. Evidence: dashboards, trends, management actions.

28. Implementation Group progression

Plan movement between IG postures based on risk, capability, dependencies, and resources. Record prerequisite gaps and sequencing. Evidence: roadmap, milestone evidence, reassessment decisions.

29. NIST CSF 2.0 and framework crosswalk governance

Use crosswalks as mapping aids, not equivalence claims. Maintain source/version identity and mapping rationale. Evidence: controlled crosswalk, reviewer/date, unresolved mapping ambiguity.

30. Source change and version migration

Monitor official CIS release/version changes, change logs, licensing terms, mappings, and Implementation Group guidance. Record impact and migration decisions; material changes reopen affected gates.

31. Assessment and audit readiness

Define assessment scope, evidence sampling, control testing, workpapers, findings, remediation, and independent-verification boundaries. Automation may collect evidence but must not replace human judgment explicitly required by the assessment context.

32. Localization, rendered QA, provenance, and release controls

Freeze exact English before es-419 and pt-BR localization. Preserve CIS terminology while marking project translations as unofficial. Require trilingual parity, documented genuine-human substantive review where explicitly required, rendered/page/accessibility QA, reproducible six-binary DOCX/PDF generation, exact SHA-256 provenance, workflow security, durable staging, predecessor publication, and catalog/release-registry reconciliation.

Controlled release boundary

This development master does not establish certification, endorsement, legal compliance, audit assurance, or publication eligibility. Release remains sequential and fail-closed under repository controls.